University of Prishtina "Hasan Prishtina"

Faculty of Electrical and Computer Engineering

White Team Documentation

Team 18: CyberBufi

Prishtinë, 2026

Table of Contents

Table of Figures 3
The Definition of Terms &Abbreviations 4
Introduction 5
1. Public Services 6
2. Network Architecture 7
3. PfSense 9
4. Servers 13
4.1 Active Directory 13
5. Ticketing Machine 21
5.1 System Purpose and Business Impact 21
5.2 Application Architecture Overview 21
5.3 Authentication and Authorization Model 22
5.4 Management Backend 22
5.5 Admin User Interface 23
6. Web Application Server (WWW) 27
7. Flags 32
References 35
References ..... **Error! Bookmark not defined.**

Table of Figures

Figure 1. Network Architecture with pfSense Firewall 9
Figure 2. Interface Assignments 11
Figure 3. Configuring the Default Gateway in pfSense 11
Figure 4. Firewall Rules – WAN Interface (pfSense) 12
Figure 5. AD Server Roles 13
Figure 6. Group Membership Analysis 15
Figure 7. Password Policy 16
Figure 8. Account Lockout Policy 16
Figure 9. Kerbos Policy 17
Figure 10. Service Account Inspectation 18
Figure 11. Authentication Configuration 19
Figure 12. Directory Event Logs 20
Figure 13. Admin Log in Page 25
Figure 14. Register Patch 26
Figure 15. Fleet Management 26
Figure 16. Log In form 27
Figure 17. Log In form Invalid 28
Figure 18. Session Configuration 29
Figure 19. Payment Vulnerability 29
Figure 20. Payment Patch 30
Figure 21. Application Logs 31
Figure 22. WWW flag Placement 33

The Definition of Terms &Abbreviations

AD- Active Directory

FTP- File Transfer Protocol

VNC- Virtual Network Computing

IP- Internet Protocol

WAN- Wide Area Network

LAN- Local Area Network

NAT- Network Address Translation

RDP- Remote Desktop Protocol

DNS- Domain Name System

IDS- Intrusion Detection System

IPS- Intrusion Prevention System

NSM- Network Security Monitoring

IPv4- Internet Protocol version 4

SSH- Secure Shell

HTTP- Hypertext Transfer Protocol

IT- Information Technology

OU- Organizational Unit

SSSD- System Security Services Daemon

GPO- Group Policy Object

Introduction

This documentation presents a detailed overview of the procedures, configurations, and security measures applied in the maintenance and management of the infrastructure provided during ICDC 2026 hosted by **Iowa State University.** The primary objective of this project was to configure, integrate, and harmonize multiple server systems in order to simulate an environment that closely resembles real-world infrastructures commonly found within the modern cyber and IT industry. Through this process, emphasis was placed not only on ensuring availability and functionality of services, but also on implementing strong security practices to protect systems from potential malicious attacks.

Throughout the project, various core networking and system administration concepts were applied, including the use of **Local Area Networks (LAN)** and **Wide Area Networks (WAN)** to manage communication between systems, along with **Internet Protocol (IP)** addressing based on **IPv4**. Services such as **Active Directory (AD)** were utilized to centrally manage users, computers, and resources, while **Organizational Units (OU)** and **Group Policy Objects (GPO)** were implemented to enforce security policies and administrative control across the network [1, 2] .

Additionally, multiple remote access and communication services were configured, including **Remote Desktop Protocol (RDP)**, **Virtual Network Computing (VNC)**, and **Secure Shell (SSH)**, allowing secure management and administration of servers. File sharing and data transfer were handled through **File Transfer Protocol (FTP)**, while web-based communication relied on **Hypertext Transfer Protocol (HTTP)**. Core infrastructure services such as the **Domain Name System (DNS)** played a critical role in ensuring reliable name resolution and network functionality.

From a security perspective, the project incorporated defensive mechanisms such as **Network Address Translation (NAT)** to control traffic flow, as well as monitoring and protection tools including **Intrusion Detection Systems (IDS)**, **Intrusion Prevention Systems (IPS)** [3] , and **Network Security Monitoring (NSM)** solutions. These technologies were used to detect, analyze, and respond to suspicious activities, reinforcing the importance of proactive defense in enterprise environments. On Linux-based systems, **System Security Services Daemon (SSSD)** was implemented to manage authentication and identity services securely.

Overall, this project demonstrates the integration of essential **Information Technology (IT)** services, networking principles, and cybersecurity practices. By combining server maintenance, service deployment, and security monitoring, the environment created reflects realistic industry standards and provides practical experience in managing and protecting enterprise-level systems against potential threats.

AI was used only as a documentation and explanation aid and not for automated decision-making [4] .

1. Public Services

Only services explicitly defined within the official ICDC 2026 competition scope were exposed to the public network. Administrative services were restricted wherever possible, and exposure was limited strictly to required ports and endpoints necessary for service functionality. The public services that are publicly available which the competition gave us are mentioned in the table below:

Domain Name	IP	Port
ad.team18.isucdc.com	175.86.94.10	389
ad.team18.isucdc.com	175.86.94.10	3389

ad.team18.isucdc.com	175.86.94.10	636
tickets.team18.isucdc.com/api/tickets/health	175.86.94.20	5000
tickets.team18.isucdc.com	175.86.94.20	3389
mgmt.team18.isucdc.com/routes	175.86.94.30	5000
mgmt.team18.isucdc.com	175.86.94.30	22
admin.team18.isucdc.com	175.86.94.40	80
admin.team18.isucdc.com	175.86.94.40	3389
www.team18.isucdc.com	175.86.94.50	80
www.team18.isucdc.com	175.86.94.50	22
admin.team18.isucdc.com/login	175.86.94.40	80
www.team18.isucdc.com/login	175.86.94.50	80

2. Network Architecture

The network architecture is designed around the pfSense firewall, which serves as the central perimeter security device and routing platform within the infrastructure. It functions as the primary boundary between the external Wide Area Network (WAN) and the internal Local Area Network (LAN), enforcing traffic inspection, access control policies, and secure communication between all systems. By positioning pfSense at the core of the topology, all inbound and outbound traffic is subject to stateful packet inspection and rule-based filtering [2].

The infrastructure provided for ICDC 2026 consists exclusively of the systems defined within the official competition scenario. These systems include the Active Directory

server, the Ticketing Machine, the Management Backend, the Admin User Interface, and the Public Website (WWW). Each server performs a clearly defined operational role and communicates with other systems through controlled and monitored channels enforced by firewall policies.

The WAN interface provides connectivity to publicly exposed services. Only services explicitly required for operational functionality were permitted through firewall rules and Network Address Translation (NAT) port forwarding configurations [5] .All other inbound traffic was denied by default, following a strict deny-by-default strategy [3] . This approach minimizes the exposed attack surface and reduces the likelihood of unauthorized external access.

The LAN interface supports internal communication between servers, including authentication requests between domain-joined systems and the Active Directory server, as well as API communication between the Ticketing Machine and the Management Backend. Inter-server communication was carefully reviewed to ensure that only necessary ports and protocols were permitted.

Network segmentation was achieved through logical separation of trust zones at the firewall level. Traffic traversing between internal segments must pass through pfSense inspection mechanisms, which reduces the risk of lateral movement in the event of system compromise. Routing tables and gateway configurations were validated to prevent asymmetric routing scenarios or unintended bypass of inspection controls.

NAT and port forwarding rules were configured with precision to ensure that each publicly accessible service is explicitly mapped to its corresponding internal host and port. Redundant and overly permissive rules were removed during auditing to prevent unintended service exposure. Outbound NAT configuration was reviewed to ensure proper internal-to-external communication while maintaining internal IP address confidentiality.

This architectural design reflects enterprise-level best practices by maintaining centralized security enforcement, minimizing exposed services, and ensuring strict separation between public-facing services and administrative components. The overall structure prioritizes availability of mission-critical services while maintaining strong defensive controls against potential adversarial activity.

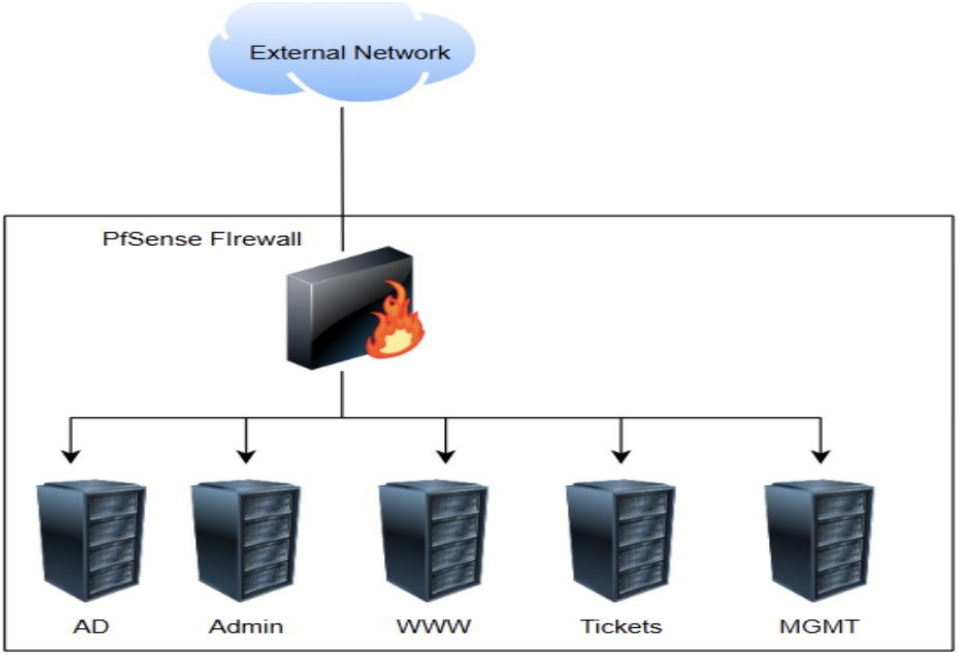

Figure 1. Network Architecture with pfSense Firewall

3. PfSense

PfSense was deployed as the primary perimeter firewall and routing platform responsible for enforcing network segmentation, controlling inbound and outbound traffic flows, and protecting internal infrastructure from unauthorized access attempts. Acting as the boundary between external and internal environments, pfSense performs stateful packet inspection, network address translation, policy enforcement, and centralized logging [2] [5] .

The firewall configuration was designed to ensure that required services remain operational while minimizing the attack surface exposed to adversarial activity [3]. Continuous auditing and rule optimization were performed to identify misconfigurations, redundant rules, and overly permissive policies that could weaken perimeter defenses.

Interface configuration defines network trust boundaries and establishes routing paths between segments. The WAN interface provides external connectivity while the LAN interface supports communication between internal hosts and servers.

Network Address Translation (NAT) and port forwarding rules were carefully configured to expose only required public services to the WAN interface. Each public service defined in the competition scope was mapped explicitly to its respective internal server and port. Unnecessary or redundant port forwarding entries were removed to prevent unintended service exposure.

Outbound NAT was reviewed to ensure proper internal-to-external communication without exposing internal addressing schemes. Port forwarding validation was performed through connectivity testing to confirm correct mapping behavior and prevent misrouting or unintended exposure.

Configuration validation included verification of IP addressing, subnet masks, gateway assignments, and interface binding. Incorrect interface configuration can lead to routing inconsistencies and potential bypass of firewall inspection mechanisms.

Segmentation achieved through interface separation ensures that traffic traversing between trust zones is subject to firewall inspection. This approach reduces the likelihood of lateral movement and limits attacker mobility following compromise of a single host.

Gateway configuration ensures proper routing of outbound traffic and enables connectivity to external networks. Routing tables were reviewed to identify unintended routes that could bypass firewall inspection or expose internal services.

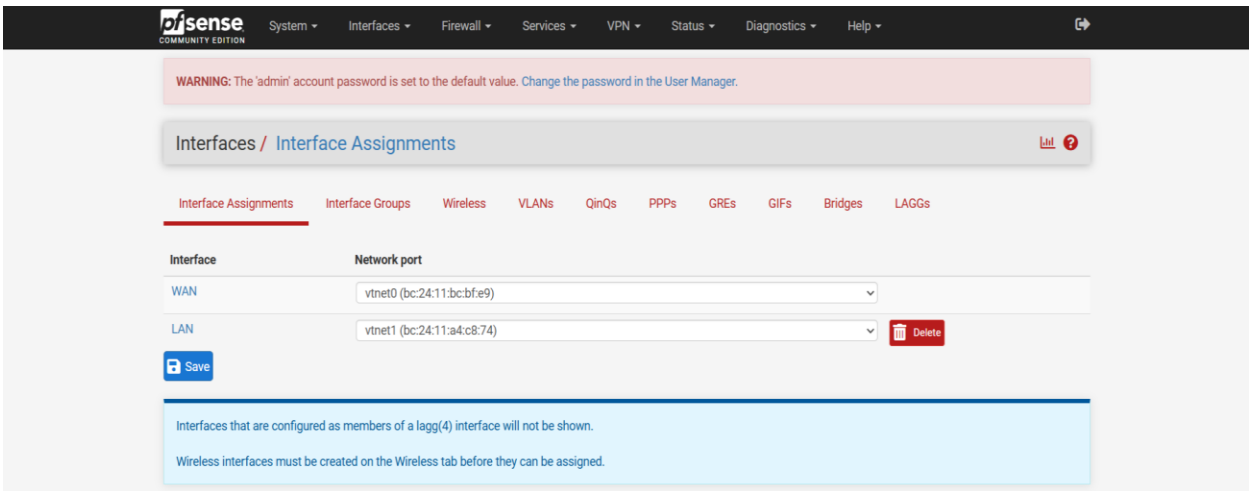

Figure 2. Interface Assignments

Connectivity testing was performed to confirm correct routing behavior and prevent asymmetric routing scenarios which may disrupt firewall state tracking.

Firewall rules were implemented using a deny by default strategy combined with explicit allow policies. This approach ensures that only required traffic is permitted while all other traffic remains implicitly blocked.

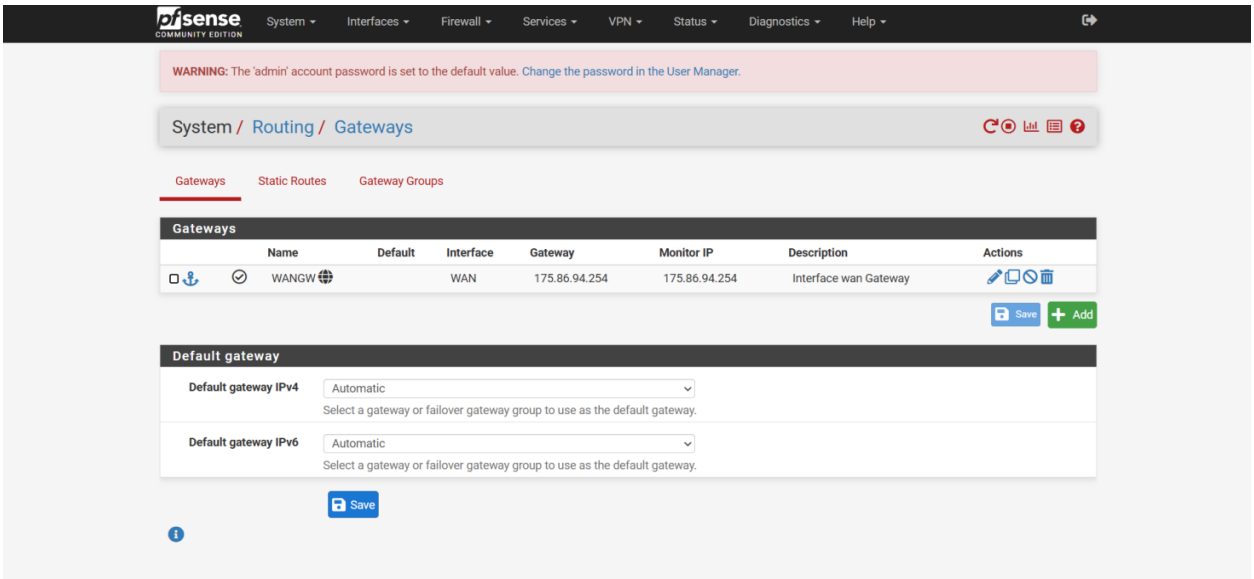

Figure 3. Configuring the Default Gateway in pfSense

WAN rules permit access to publicly exposed services while restricting administrative protocols and backend services. LAN rules allow internal communication required for operational functionality while preventing unauthorized inter host access.

Rule ordering was validated to ensure correct precedence and prevent unintended rule matching. Misordered rules can permit unauthorized traffic or block legitimate communication.

Auditing of firewall policies revealed redundant and permissive rules that expanded the attack surface. Optimization steps included removal of duplicate rules, tightening of source restrictions, and restriction of unnecessary outbound communication.

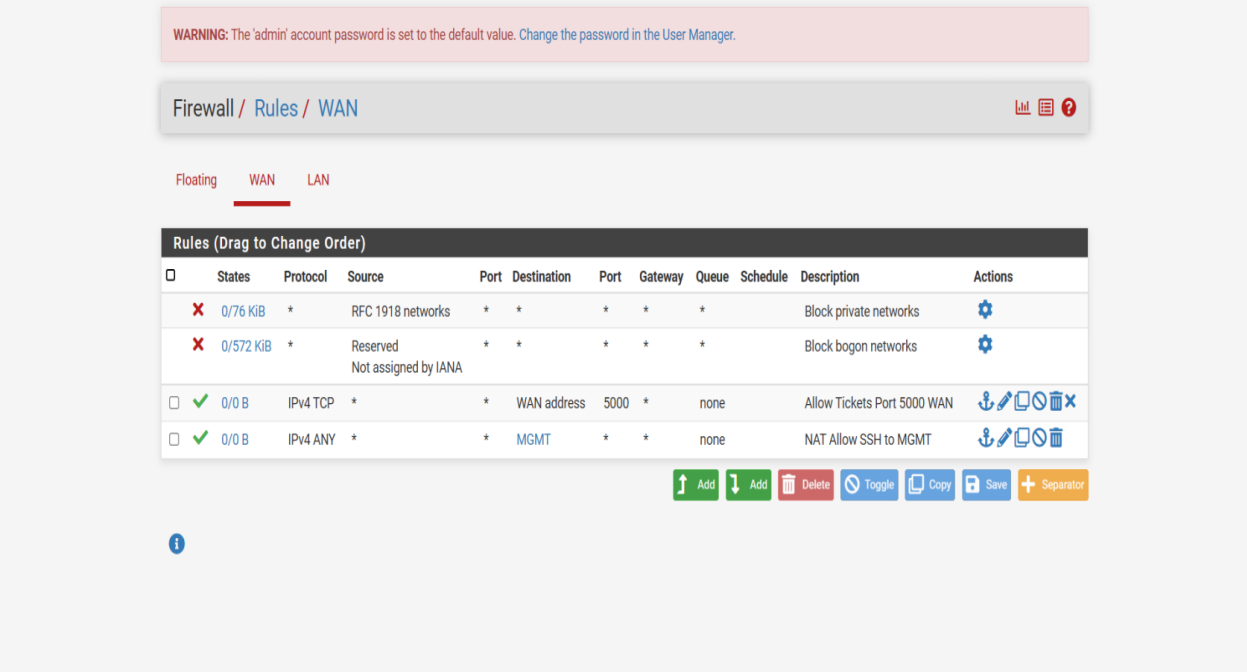

Figure 4. Firewall Rules – WAN Interface (pfSense)

Rule optimization improves clarity and ensures consistent enforcement of access control policies.

4. Servers

4.1 Active Directory

Active Directory is a proprietary directory service developed by Microsoft® to provide secure access to corporate networks. Active Directory stores information related to user accounts, computer objects, groups, policies and other resources on the network. It also provides an efficient way for administrators to manage the security settings of their organization's IT infrastructure.

These are the six main components of AD: Active Directory Domain Services, Domain Controller, Lightweight Directory Services, Federation Services, Rights Management Services, and Certificate Services [6]

- **Active Directory Domain Services (AD DS)**: Active Directory Domain Services (AD DS) provides directory services for managing Windows-based computers on a network. AD DS stores information about objects such as users, groups, computers, and other resources, and provides authentication and authorization services.

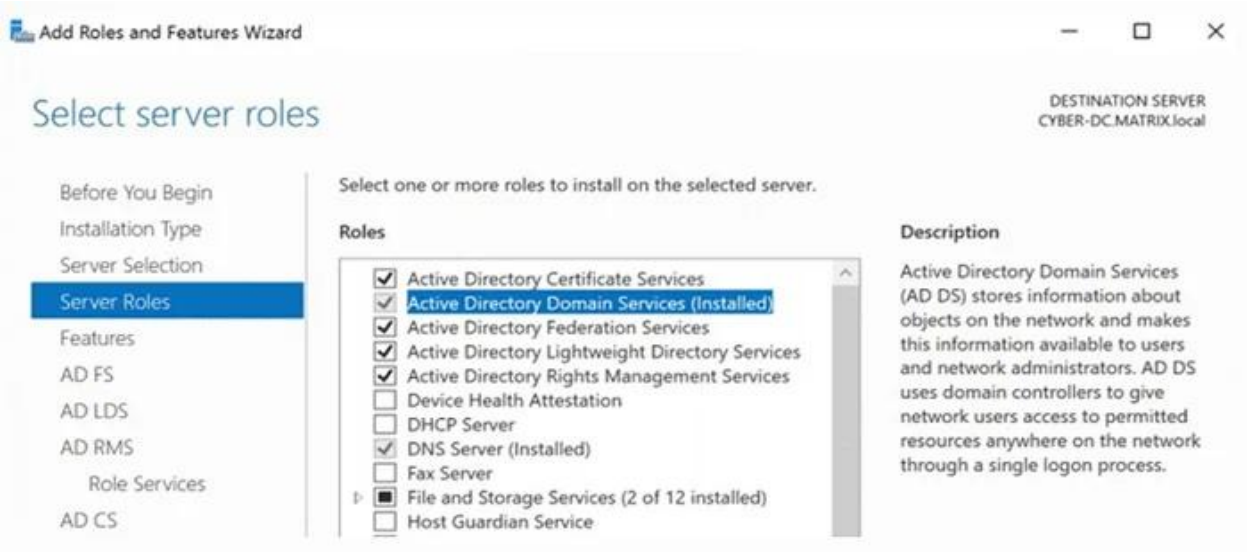

Figure 5. AD Server Roles

- **Domain Controller**: A domain controller (DC) is a network server that responds to security authentication requests and authorizes host access to domain resources. This server enforces security policies, authenticates registered users, and stores important user account information. Domain controllers manage and secure domain networks by only allowing authorized users access to directory services while denying unauthorized access.

- **Lightweight Directory Services (AD LDS)**: AD LDS is a Lightweight Directory Access Protocol (LDAP) directory service that offers dedicated data storage and APIs for accessing stored information. It functions independently of Active Directory and can function as a standalone data store or can replicate data.

- **Federation Services (AD FS)**: Active Directory Federation Services (AD FS) is a service that allows the secure sharing of identity information between trusted business partners. It is based on industry standards and facilitates federations across extranets, enabling trusted partners to share sensitive identity data.

- **Rights Management Services (AD RMS)**: AD RMS enables users and admins to control access permissions for sensitive documents, workbooks, and presentations. By utilizing IRM policies, unauthorized individuals are prevented from duplicating and disseminating the restricted information.

- **Certificate Services (AD CS)**: Active Directory Certificate Services (AD CS) is a Windows server designed to issue digital certificates. AD CS offers digital certificates that have a wide range of applications, including the encryption and digital signing of documents and messages, as well as authenticating computer, user, or device accounts

on a network. Certificates granted by AD CS are valid for a specified period and can be renewed or revoked as needed, providing granular control over the certificates' lifespan.

The domain controller was configured to provide directory services, authentication, and centralized policy enforcement. Configuration validation included verification of domain naming, DNS integration, replication status, and service health.

Group membership was analyzed to identify privilege escalation risks associated with excessive group assignments. Membership in high privilege groups such as administrators or domain admins significantly increases impact of credential compromise.

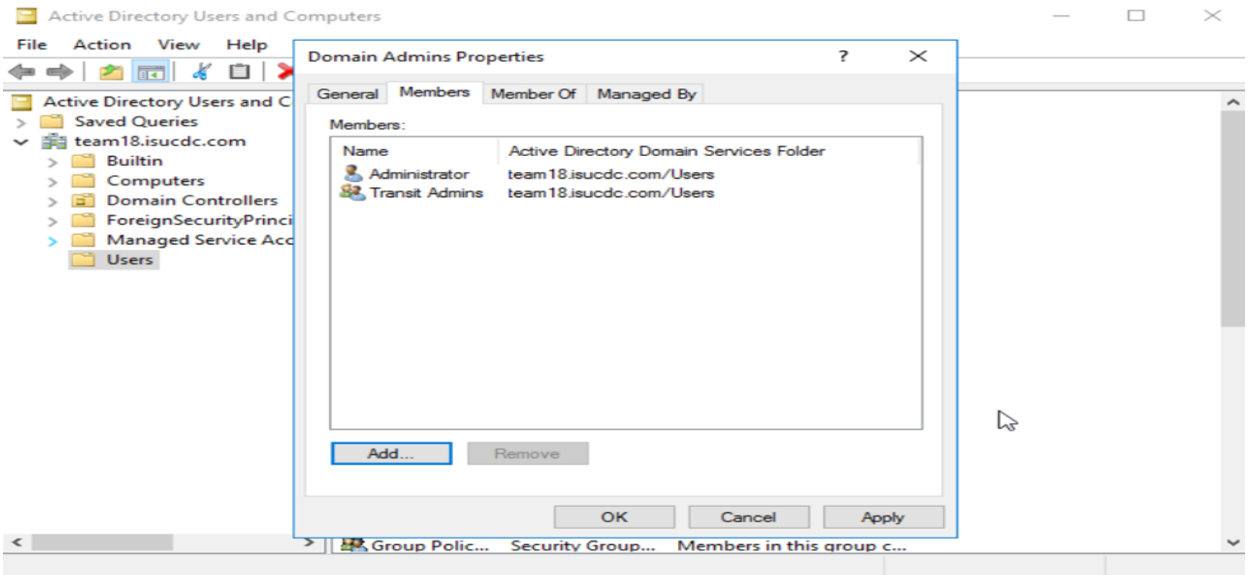

Figure 6. Group Membership Analysis

Mitigation actions included removal of unnecessary group assignments and enforcement of least privilege principles [3].

Group policies were configured to enforce password complexity, account lockout thresholds, login restrictions, and endpoint security settings. Policy enforcement ensures consistent security controls across domain joined systems.

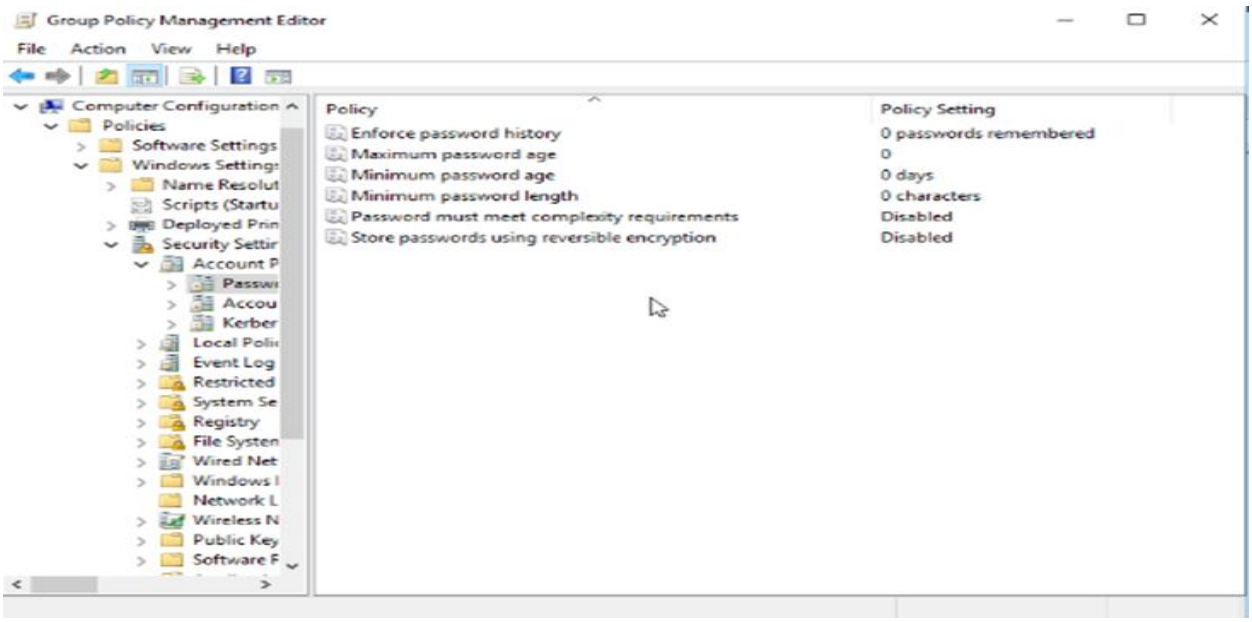

Figure 7. Password Policy

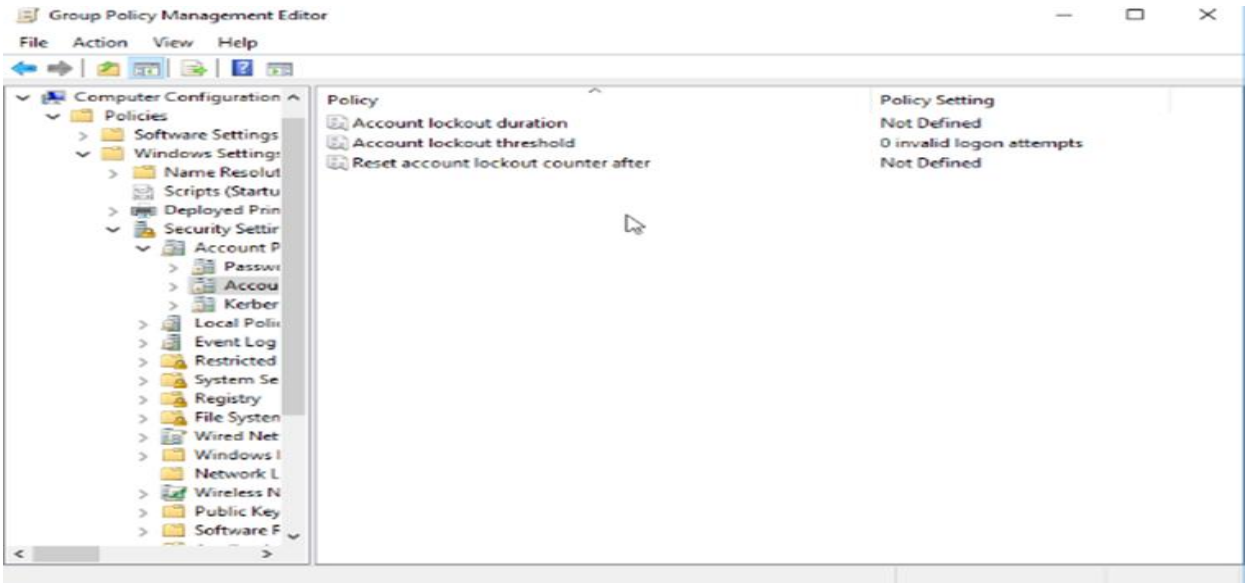

Figure 8. Account Lockout Policy

Password policy enforcement mitigates brute force and credential guessing attacks, while account lockout thresholds prevent repeated authentication attempts.

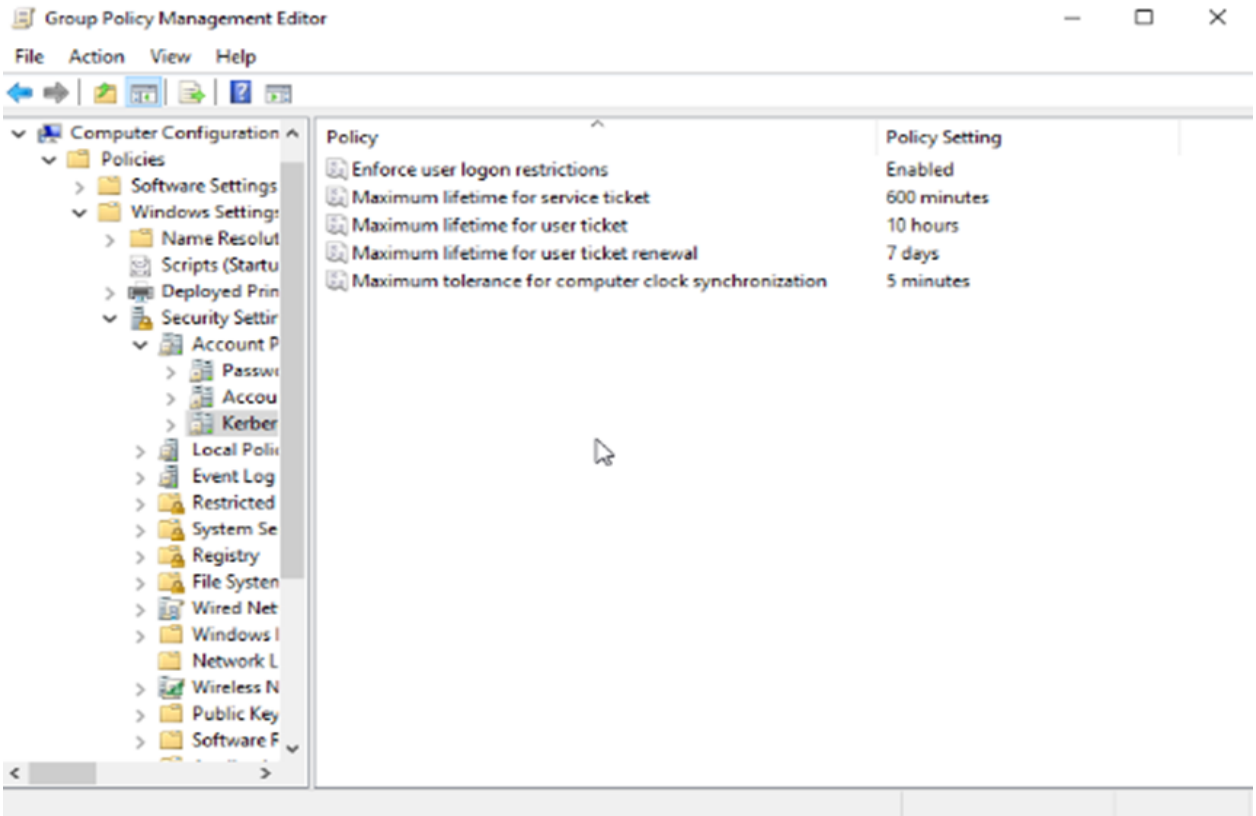

Figure 9. Kerbos Policy

Service accounts were reviewed to identify excessive privileges and persistence risks. Service accounts often remain overlooked and may provide attackers with privileged access if compromised.

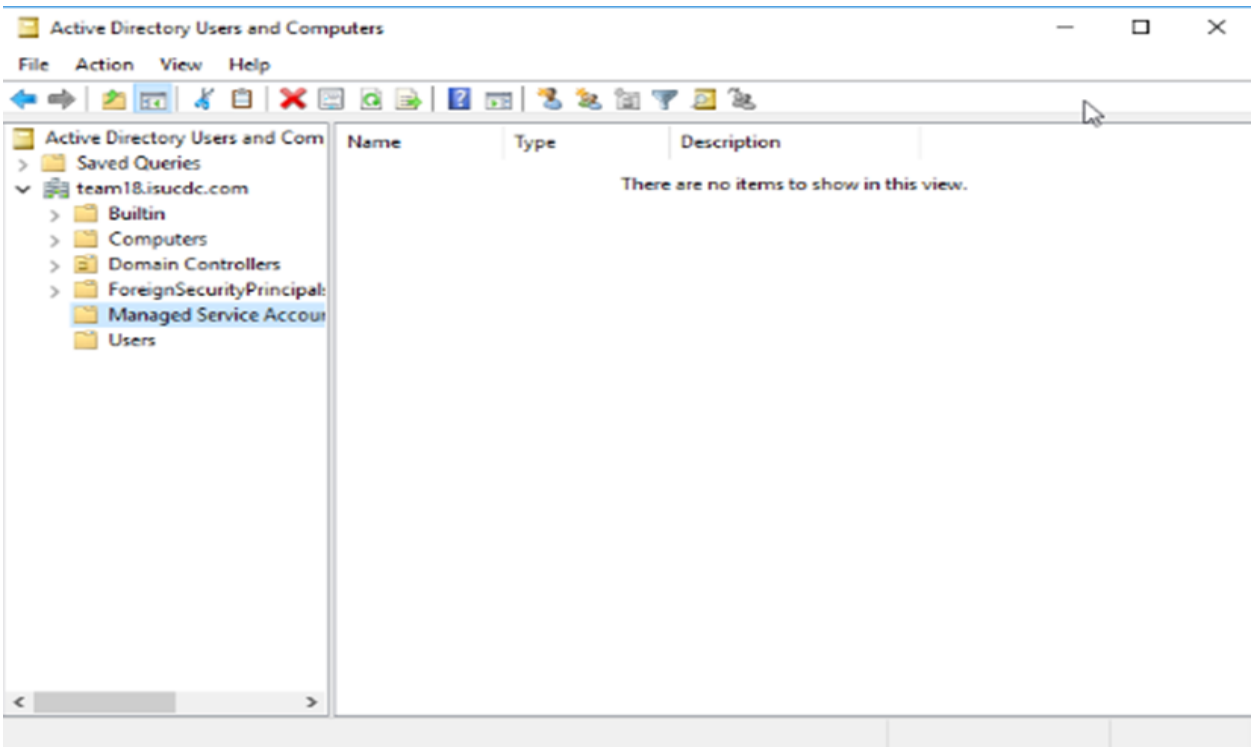

Figure 10. Service Account Inspectation

Auditing included verification of password configuration, privilege assignment, and service dependencies. Excessive privileges were removed and unused service accounts disabled.

Authentication mechanisms were reviewed to ensure secure protocols and strong credential protection. NTLM usage and insecure authentication mechanisms were evaluated for potential risk.

Mitigation actions included enforcing secure authentication protocols and monitoring authentication events for anomalies.

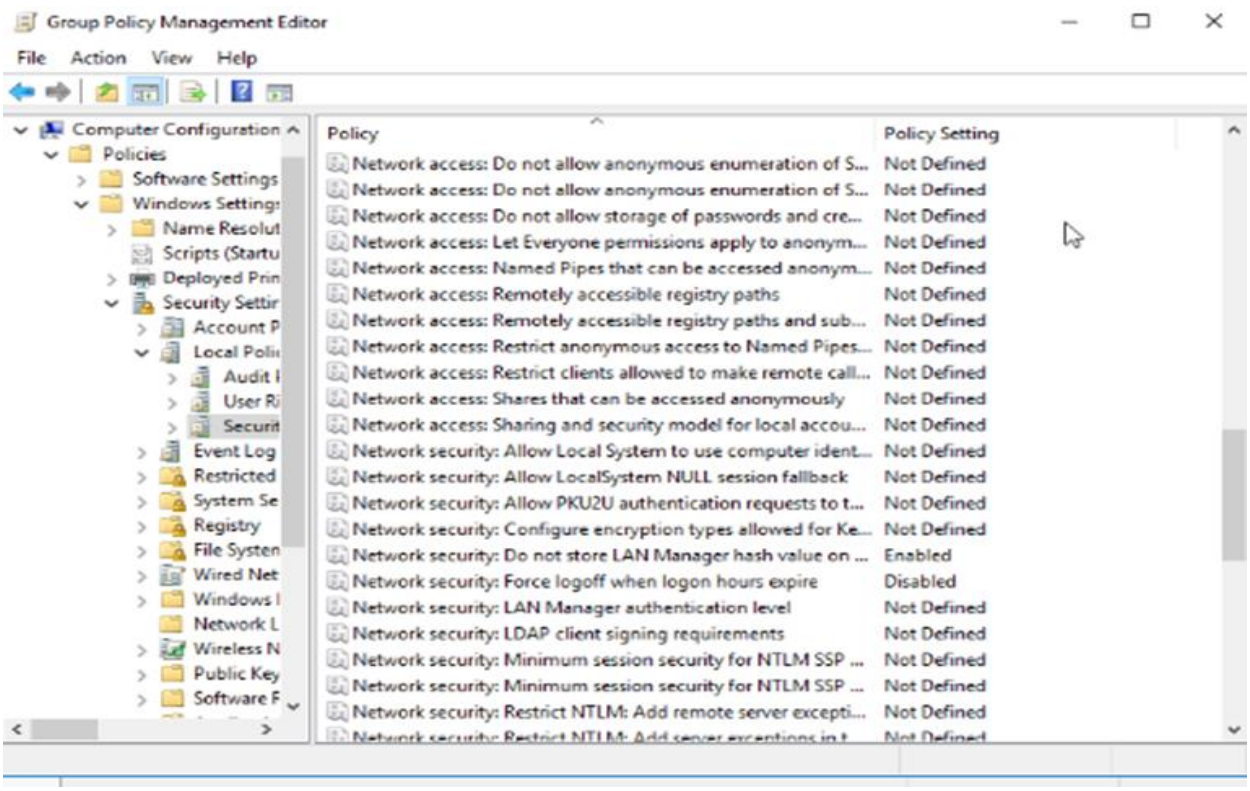

Figure 11. Authentication Configuration

Active Directory logging was enabled to monitor authentication events [6] privilege changes, account modifications, and policy enforcement actions. Logging provides critical visibility into suspicious activity and supports incident response.

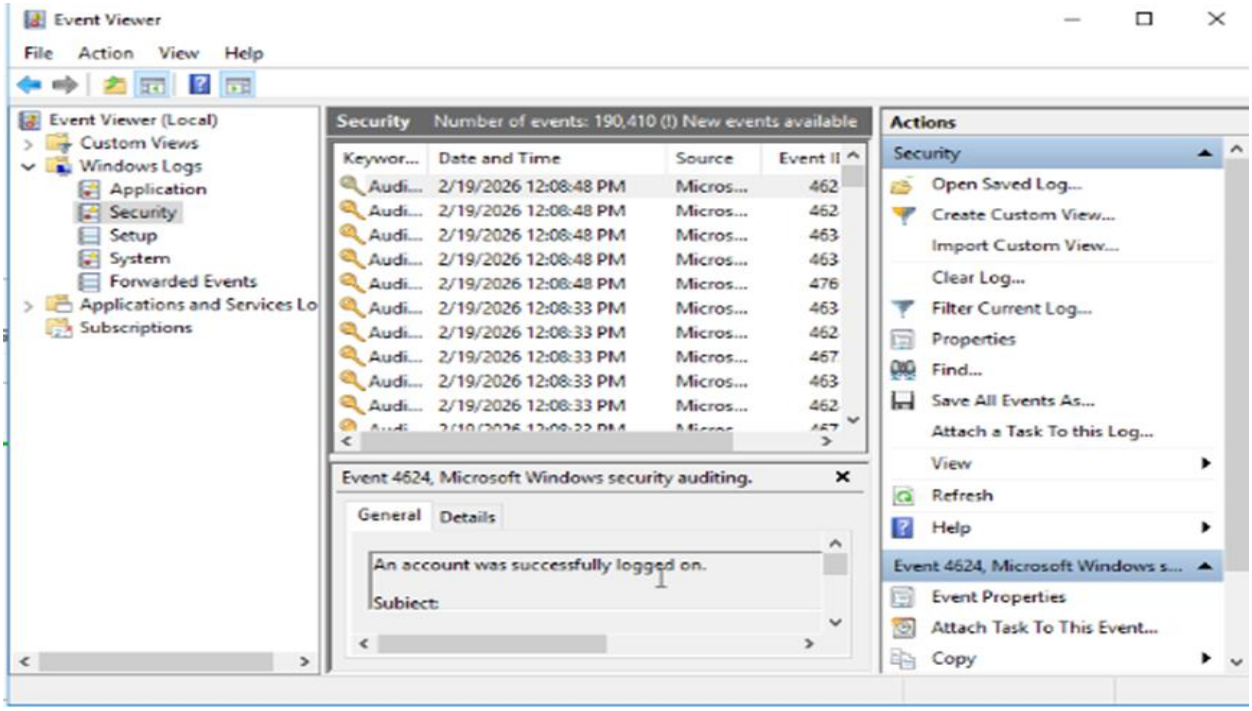

Figure 12. Directory Event Logs

Event log analysis supports detection of brute force attempts, unauthorized privilege changes, and persistence activities.

DNS integration is essential for proper authentication workflows. Misconfigured DNS can disrupt domain functionality and create opportunities for credential interception or authentication bypass.

Connectivity testing was performed to confirm successful domain join operations and ensure reliable communication between domain clients and the domain controller.

Auditing identified potential vulnerabilities including excessive privileges, dormant accounts, misconfigured delegation, weak password policies, and insufficient monitoring. These vulnerabilities could enable privilege escalation, persistence, and unauthorized access.

Mitigation actions included removal of unauthorized accounts, enforcement of password complexity, reduction of group membership privileges, tightening of delegation permissions, and implementation of monitoring controls.

These hardening measures significantly improved directory security and reduced the risk of credential compromise and privilege escalation.

5. Ticketing Machine

5.1 System Purpose and Business Impact

The Ticketing Machine represents a mission-critical backend component responsible for issuing, validating, and verifying digital tickets for buses and trains across Central Downtown City. This system directly impacts revenue generation, fare enforcement, and public trust in the transportation system. Any compromise of this system could enable large-scale ticket fraud, financial loss, and reputational damage to the city.

The Ticketing Machine is one of the highest-value targets for adversaries due to its interaction with cryptographic trust mechanisms, expiration logic, and backend validation processes. As such, it was treated as a high-risk asset requiring layered defensive controls.

5.2 Application Architecture Overview

The ticketing application is hosted on Windows Server 2019 and operates as a backend service listening on TCP port 5000. The application is responsible for: Generating tickets with cryptographically verifiable attributes; Validating ticket authenticity and expiration; Communicating with the Management Backend; Supporting simulated physical ticket readers.

The application is started automatically at system boot using a scheduled task. This design decision was reviewed carefully due to the elevated risk associated with scheduled task abuse as a persistence mechanism.

5.3 Authentication and Authorization Model

The Ticketing Machine relies on Active Directory for administrator authentication via RDP. Domain membership ensures centralized identity control, password policy enforcement, and logging consistency.

Authorization for system-level actions is restricted to administrative users. Application-level authorization is enforced by the backend logic and trust relationships with the Management Backend.

From a defensive standpoint, separation between system administration and application logic reduces the risk of full system compromise following an application-level vulnerability.

5.4 Management Backend

The Management Backend server represents the core operational component of the Central Downtown City transportation infrastructure. This system is responsible for managing fleet operations, route data, administrative actions, authentication validation, and payment processing logic.

The backend operates on AlmaLinux 8.4 and runs as a systemd service named backend, listening on TCP port 5000. Due to its critical role in handling financial records and operational commands, it was classified as a high-value asset requiring strict hardening and continuous monitoring.

The service was configured to start automatically on boot to ensure service availability throughout the competition.

From a security perspective, several hardening measures were implemented. Root SSH login was disabled to reduce brute force exposure. Key-based authentication was enforced for administrative access. Firewall configuration using firewalld ensured that only required ports were exposed, specifically port 22 for SSH (restricted) and port 5000 for application communication.

SELinux was verified to be in enforcing mode [5] to provide mandatory access control. Unnecessary packages and services were removed to reduce the attack surface [3] .

System auditing was verified through auditd to ensure system-level event tracking and accountability[6]. Audit logs provide visibility into privilege escalation attempts, configuration changes, and suspicious command execution patterns.

Database security was reviewed to ensure that only the backend service account had access to the application database. Default and test accounts were removed, and sensitive credentials were secured within configuration files.

Special attention was given to the protection of the “blue_flag” payment record stored within the database. Authorization validation was tested to prevent unauthorized modification or deletion of financial records.

5.5 Admin User Interface

The Admin User Interface server operates on Windows Server 2022 and provides administrative control over transportation services. This web-based interface allows authorized personnel to manage vehicles, routes, and operational status.

Given its administrative capabilities, this server represents a critical control point within the infrastructure. Any compromise of this system could enable large-scale service disruption.

The application is accessible over HTTP on port 80 and administrative access is provided via RDP on port 3389. RDP access was restricted exclusively to IT Administrators to minimize exposure.

Authentication is integrated with Active Directory, ensuring centralized credential management and logging.

Role-based access control was verified to ensure that only authorized administrative accounts could disable vehicles or modify operational parameters. Special attention was given to the "disable all vehicles" functionality to ensure proper authorization checks were enforced.

Windows Firewall rules were audited to confirm that only required services were exposed. Scheduled task configuration was reviewed to ensure the application starts reliably on system boot without introducing persistence risks.

Logging and event monitoring were enabled to detect unauthorized login attempts and suspicious activity.

These controls reduce the risk of administrative takeover and service disruption.

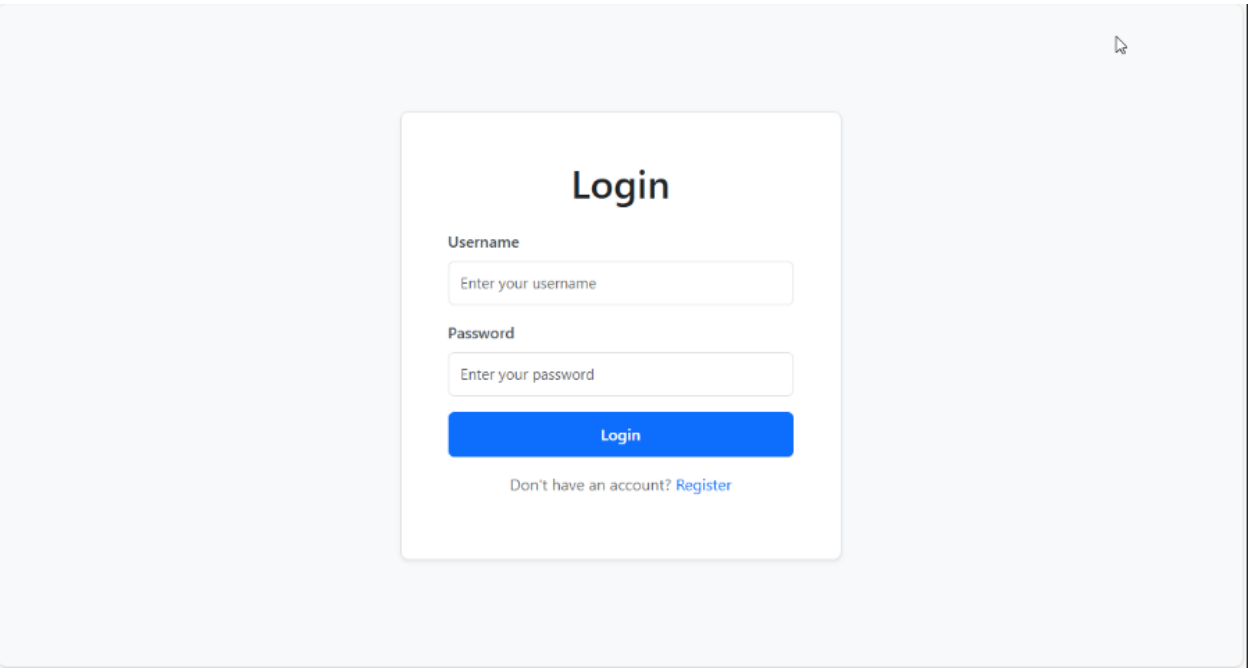

Figure 13. Admin Log in Page

Something we changed in the code is the Register button, we made it that the red team cant register an account and have the admin commands, since it would lower the system security and be in the hands of the bad people.

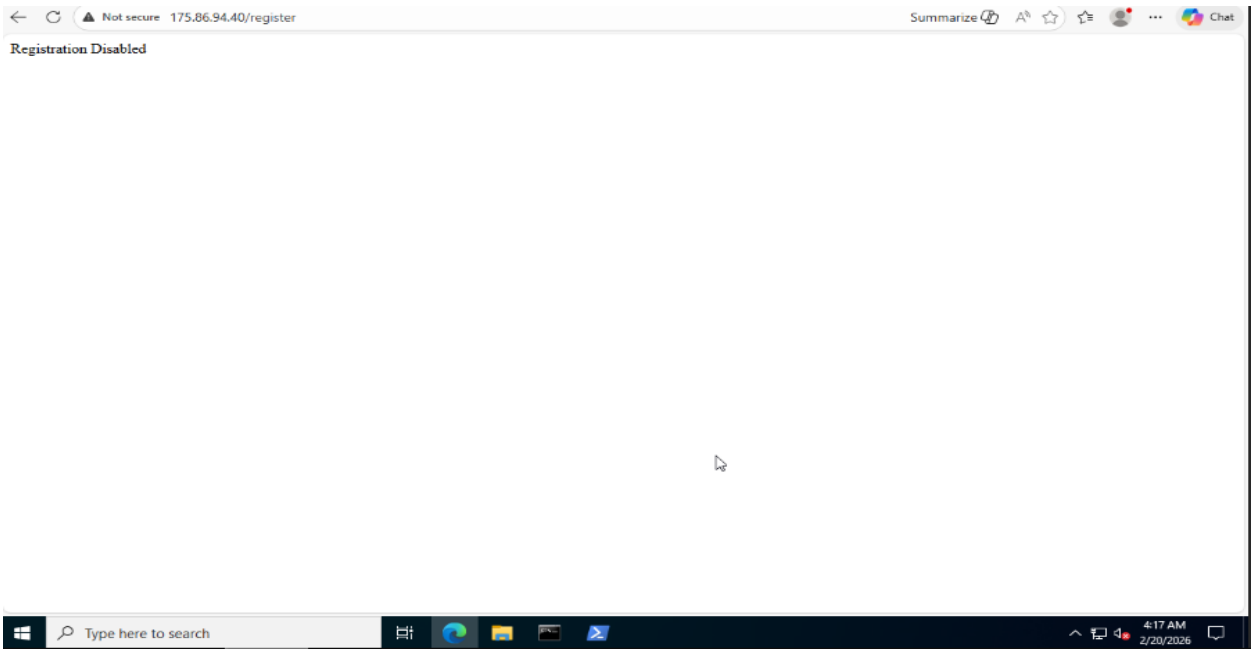

Figure 14. Register Patch

In the admin website, there is also the option where u can control the trains, buses and vehicles.

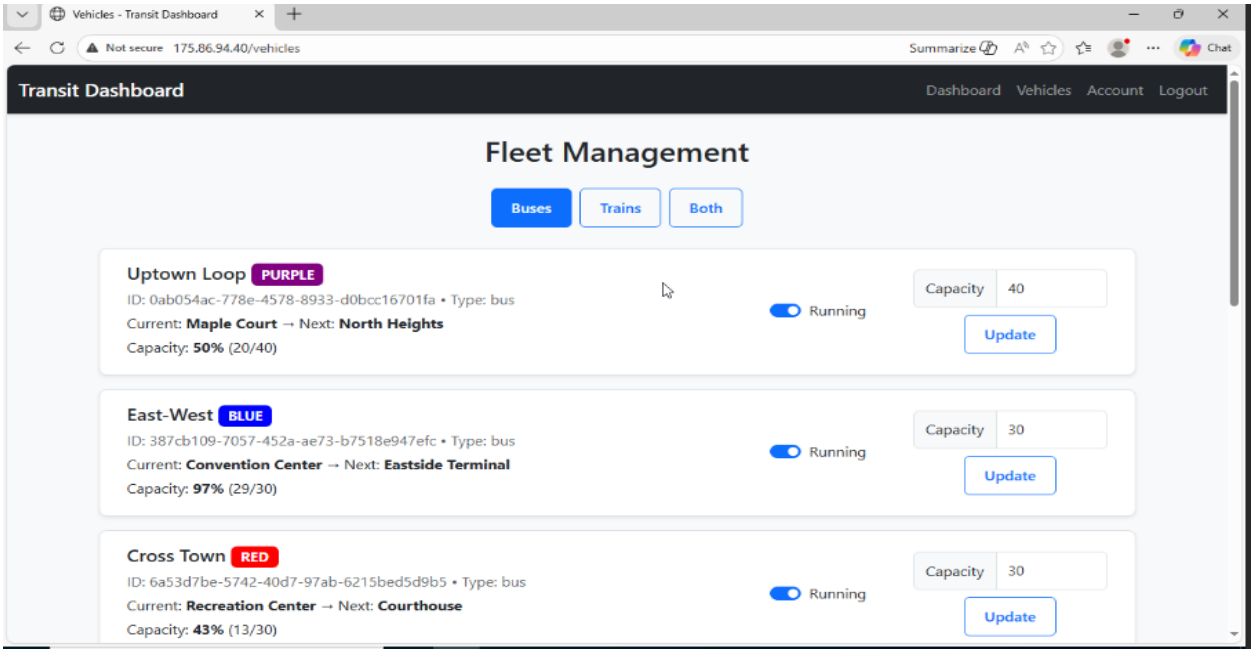

Figure 15. Fleet Management

6. Web Application Server (WWW)

The web application server was deployed as the primary interface through which users interact with application functionality. Due to its public accessibility and direct exposure to user supplied input, the web server presents one of the highest risk components within the infrastructure. Misconfigurations, insecure coding practices, and insufficient input validation can enable exploitation attempts such as remote code execution, authentication bypass, and data leakage [7].

Security auditing of the web server focused on service exposure analysis, file upload validation, authentication logic verification, session management inspection, and application code review. These activities were essential to identify vulnerabilities that could compromise application integrity and backend infrastructure.

Authentication mechanisms were reviewed to identify potential bypass vulnerabilities and session management weaknesses. Administrative endpoints were examined to ensure proper authorization checks and session validation.

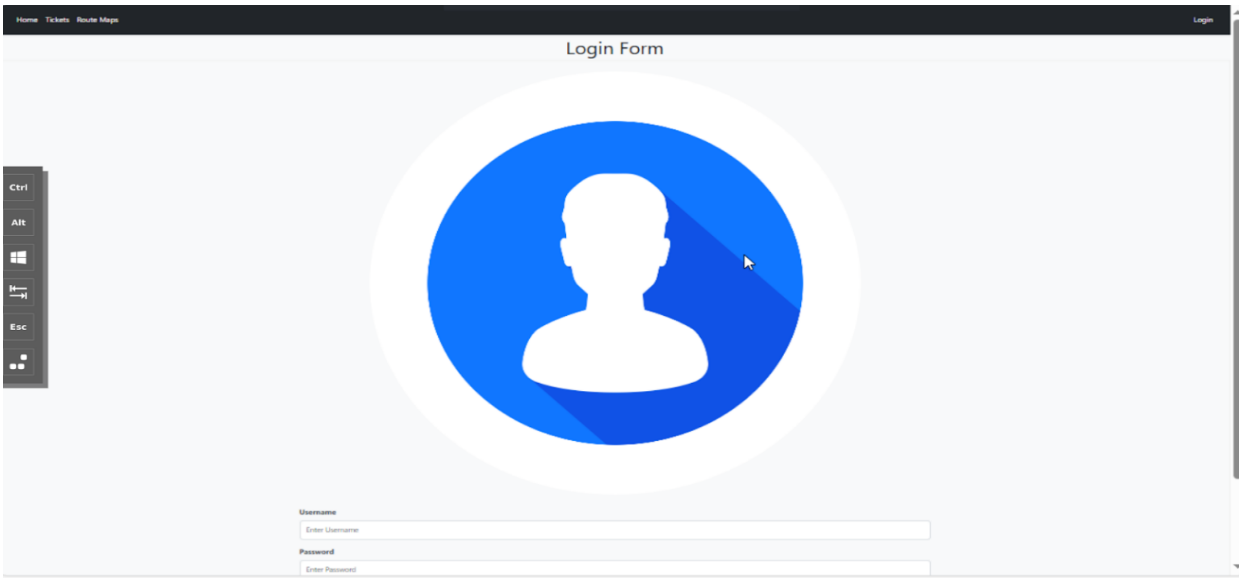

Figure 16. Log In form

Auditing revealed instances of insufficient validation allowing unauthorized access attempts to sensitive endpoints.

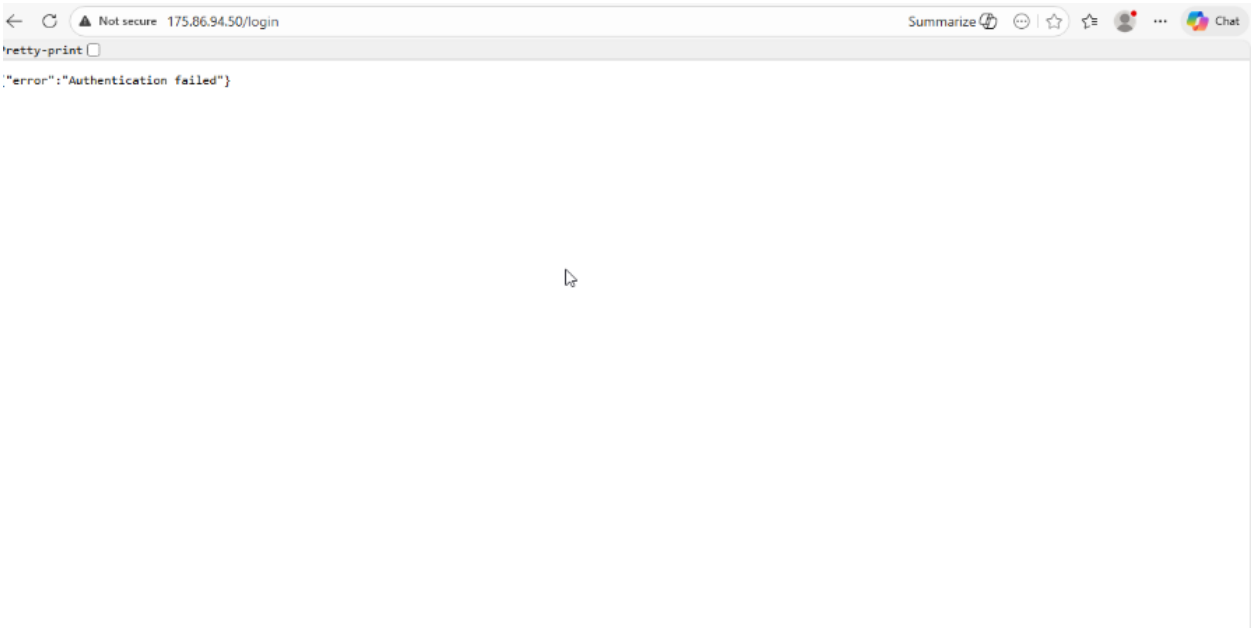

Figure 17. Log In form Invalid

Figure 13 illustrates the system response when an incorrect username is provided during the authentication process. The application denies access and returns an error message without revealing whether the username exists in the system.This behavior prevents user enumeration attacs and ensures that authentication feedback does not disclose sensitive information to potential attackers.

Session management mechanisms were evaluated to ensure secure token handling and expiration policies. Weak session management can enable session hijacking and unauthorized access [7].

Mitigation included enforcing token validation, implementing expiration policies, and restricting token exposure within application responses.

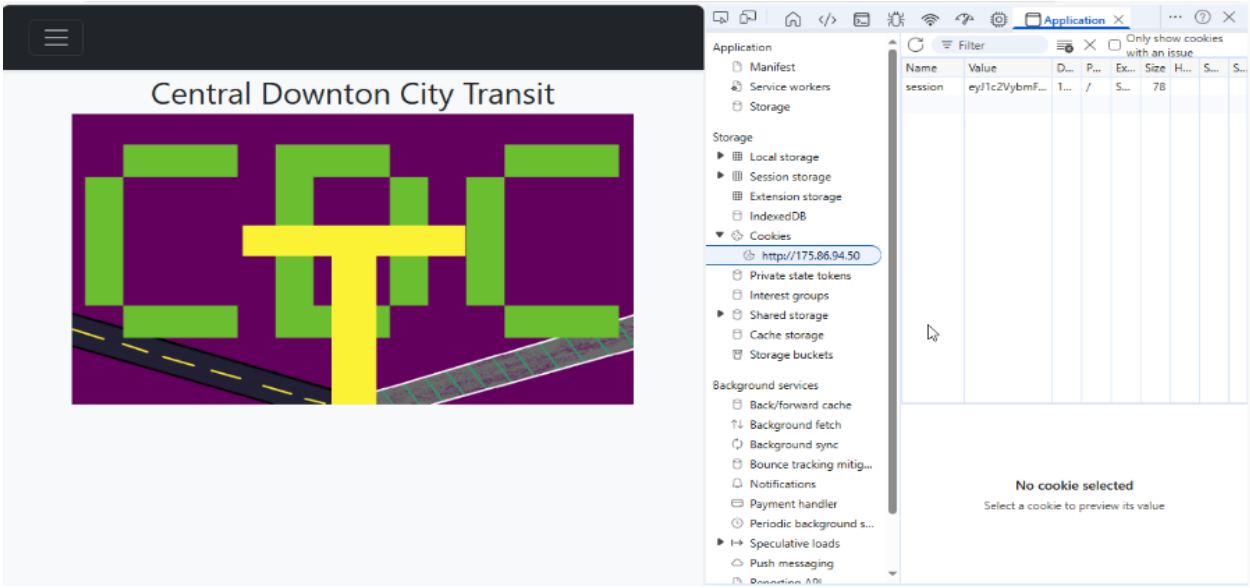

Figure 18. Session Configuration

Application code review identified vulnerabilities within payment processing logic including token exposure and insufficient validation of request parameters. Exposure of payment tokens can enable unauthorized transaction manipulation and data leakage.

Figure 19. Payment Vulnerability

This vulnerability represents a critical risk due to potential financial impact and data compromise.

Mitigation involved enforcing authorization headers, restricting token exposure, validating request parameters, and sanitizing input data. Code patches were applied to address insecure logic and improve request validation [3] 7.

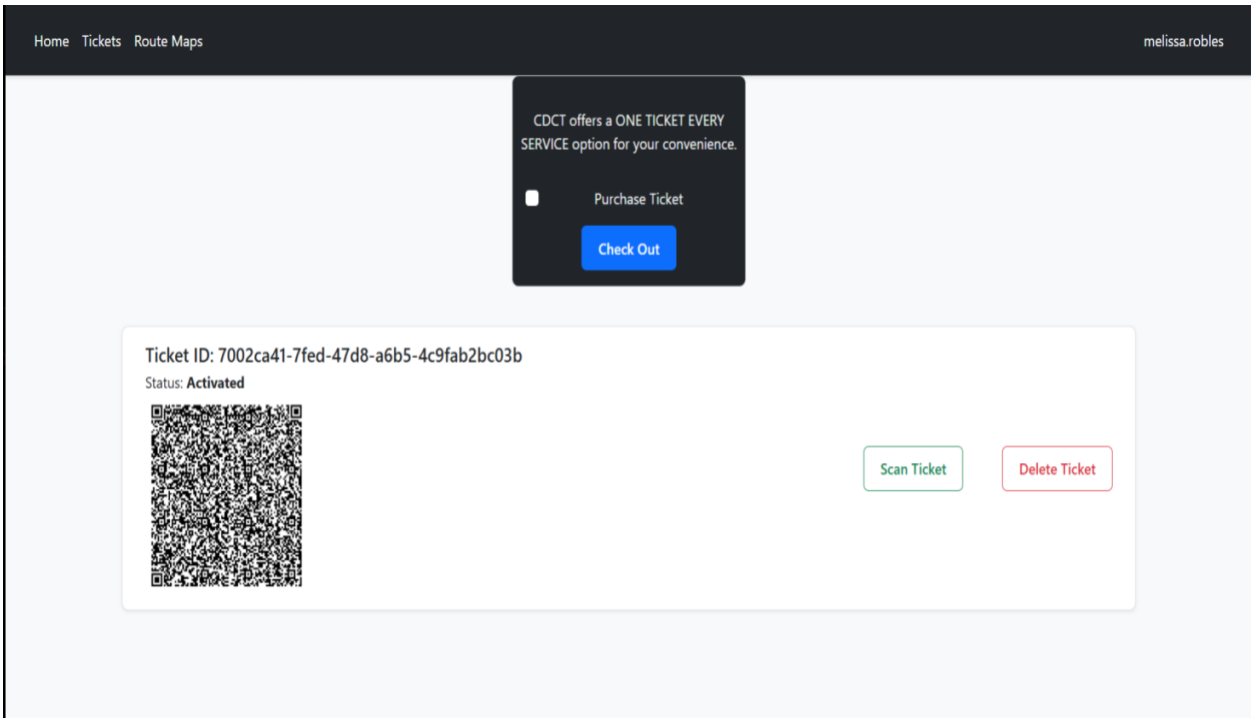

Figure 20. Payment Patch

These improvements significantly reduce the risk of payment manipulation and unauthorized transaction processing.

Application logging was enabled to monitor authentication attempts, file uploads, error conditions, and suspicious requests. Logging provides visibility into exploitation attempts and supports forensic analysis.

```
Feb 19 13:47:30 www.team18.isucdc.com flask[962]: 199.100.16.100 - - [19/Feb/2026 13:47:30] "POST /login HTTP/1.1" 401 -
Feb 19 13:48:05 www.team18.isucdc.com flask[962]: 199.100.16.100 - - [19/Feb/2026 13:48:05] "POST /login HTTP/1.1" 200 -
Feb 19 13:48:05 www.team18.isucdc.com flask[962]: 199.100.16.100 - - [19/Feb/2026 13:48:05] "GET /static/css/style.css HTTP/1.1" 304 -
Feb 19 13:48:05 www.team18.isucdc.com flask[962]: 199.100.16.100 - - [19/Feb/2026 13:48:05] "GET /static/images/Logo.png HTTP/1.1" 304 -
Feb 19 13:49:00 www.team18.isucdc.com flask[962]: 12.110.205.183 - - [19/Feb/2026 13:49:00] "GET / HTTP/1.1" 200 -
Feb 19 13:49:00 www.team18.isucdc.com flask[962]: 12.110.205.183 - - [19/Feb/2026 13:49:00] "GET /login HTTP/1.1" 200 -
Feb 19 13:49:00 www.team18.isucdc.com flask[962]: 12.110.205.183 - - [19/Feb/2026 13:49:00] "POST /login HTTP/1.1" 200 -
Feb 19 13:49:05 www.team18.isucdc.com flask[962]: 199.100.16.100 - - [19/Feb/2026 13:49:05] "GET /static/css/style.css HTTP/1.1" 304 -
Feb 19 13:54:00 www.team18.isucdc.com flask[962]: 68.32.254.50 - - [19/Feb/2026 13:54:00] "GET / HTTP/1.1" 200 -
Feb 19 13:54:00 www.team18.isucdc.com flask[962]: 68.32.254.50 - - [19/Feb/2026 13:54:00] "GET /login HTTP/1.1" 200 -
Feb 19 13:54:00 www.team18.isucdc.com flask[962]: 68.32.254.50 - - [19/Feb/2026 13:54:00] "POST /login HTTP/1.1" 200 -
Feb 19 13:55:58 www.team18.isucdc.com flask[962]: 199.100.16.100 - - [19/Feb/2026 13:55:58] "GET /tickets HTTP/1.1" 200 -
Feb 19 13:55:58 www.team18.isucdc.com flask[962]: 199.100.16.100 - - [19/Feb/2026 13:55:58] "GET /static/js/tickets.js HTTP/1.1" 200 -
Feb 19 13:55:58 www.team18.isucdc.com flask[962]: 199.100.16.100 - - [19/Feb/2026 13:55:58] "GET /static/css/style.css HTTP/1.1" 304 -
Feb 19 13:55:58 www.team18.isucdc.com flask[962]: 199.100.16.100 - - [19/Feb/2026 13:55:58] "GET /get_tickets HTTP/1.1" 200 -
Feb 19 13:56:09 www.team18.isucdc.com flask[962]: 199.100.16.100 - - [19/Feb/2026 13:56:09] "GET /buy_ticket?check=on HTTP/1.1" 400 -
Feb 19 13:59:00 www.team18.isucdc.com flask[962]: 12.110.205.184 - - [19/Feb/2026 13:59:00] "GET /login HTTP/1.1" 200 -
Feb 19 13:59:00 www.team18.isucdc.com flask[962]: 12.110.205.184 - - [19/Feb/2026 13:59:00] "GET / HTTP/1.1" 200 -
Feb 19 13:59:00 www.team18.isucdc.com flask[962]: 12.110.205.184 - - [19/Feb/2026 13:59:00] "POST /login HTTP/1.1" 200 -
Feb 19 14:04:00 www.team18.isucdc.com flask[962]: 68.32.254.50 - - [19/Feb/2026 14:04:00] "GET / HTTP/1.1" 200 -
Feb 19 14:04:00 www.team18.isucdc.com flask[962]: 68.32.254.50 - - [19/Feb/2026 14:04:00] "GET /login HTTP/1.1" 200 -
Feb 19 14:04:01 www.team18.isucdc.com flask[962]: 68.32.254.50 - - [19/Feb/2026 14:04:01] "POST /login HTTP/1.1" 200 -
Feb 19 14:09:00 www.team18.isucdc.com flask[962]: 12.110.205.185 - - [19/Feb/2026 14:09:00] "GET / HTTP/1.1" 200 -
Feb 19 14:09:00 www.team18.isucdc.com flask[962]: 12.110.205.185 - - [19/Feb/2026 14:09:00] "GET /login HTTP/1.1" 200 -
Feb 19 14:09:00 www.team18.isucdc.com flask[962]: 12.110.205.185 - - [19/Feb/2026 14:09:00] "POST /login HTTP/1.1" 200 -
Feb 19 14:14:00 www.team18.isucdc.com flask[962]: 68.32.254.50 - - [19/Feb/2026 14:14:00] "GET / HTTP/1.1" 200 -
Feb 19 14:14:00 www.team18.isucdc.com flask[962]: 68.32.254.50 - - [19/Feb/2026 14:14:00] "GET /login HTTP/1.1" 200 -
Feb 19 14:14:01 www.team18.isucdc.com flask[962]: 68.32.254.50 - - [19/Feb/2026 14:14:01] "POST /login HTTP/1.1" 200 -
Feb 19 14:19:00 www.team18.isucdc.com flask[962]: 12.110.205.186 - - [19/Feb/2026 14:19:00] "GET / HTTP/1.1" 200 -
Feb 19 14:19:00 www.team18.isucdc.com flask[962]: 12.110.205.186 - - [19/Feb/2026 14:19:00] "GET /login HTTP/1.1" 200 -
Feb 19 14:19:00 www.team18.isucdc.com flask[962]: 12.110.205.186 - - [19/Feb/2026 14:19:00] "POST /login HTTP/1.1" 200 -
Feb 19 14:24:00 www.team18.isucdc.com flask[962]: 68.32.254.50 - - [19/Feb/2026 14:24:00] "GET /login HTTP/1.1" 200 -
Feb 19 14:24:00 www.team18.isucdc.com flask[962]: 68.32.254.50 - - [19/Feb/2026 14:24:00] "GET / HTTP/1.1" 200 -
Feb 19 14:24:00 www.team18.isucdc.com flask[962]: 68.32.254.50 - - [19/Feb/2026 14:24:00] "POST /login HTTP/1.1" 200 -
Feb 19 14:29:00 www.team18.isucdc.com flask[962]: 12.110.205.187 - - [19/Feb/2026 14:29:00] "GET /login HTTP/1.1" 200 -
Feb 19 14:29:00 www.team18.isucdc.com flask[962]: 12.110.205.187 - - [19/Feb/2026 14:29:00] "GET / HTTP/1.1" 200 -
Feb 19 14:29:00 www.team18.isucdc.com flask[962]: 12.110.205.187 - - [19/Feb/2026 14:29:00] "POST /login HTTP/1.1" 200 -
Feb 19 14:30:04 www.team18.isucdc.com flask[962]: 199.100.16.101 - - [19/Feb/2026 14:30:04] "GET / HTTP/1.1" 200 -
Feb 19 14:30:05 www.team18.isucdc.com flask[962]: 199.100.16.101 - - [19/Feb/2026 14:30:05] "GET /static/css/style.css HTTP/1.1" 304 -
Feb 19 14:30:05 www.team18.isucdc.com flask[962]: 199.100.16.101 - - [19/Feb/2026 14:30:05] "GET /static/images/Logo.png HTTP/1.1" 304 -
Feb 19 14:30:05 www.team18.isucdc.com flask[962]: 199.100.16.101 - - [19/Feb/2026 14:30:05] "GET /favicon.ico HTTP/1.1" 404 -
Feb 19 14:30:07 www.team18.isucdc.com flask[962]: 199.100.16.101 - - [19/Feb/2026 14:30:07] "GET /tickets HTTP/1.1" 200 -
Feb 19 14:30:08 www.team18.isucdc.com flask[962]: 199.100.16.101 - - [19/Feb/2026 14:30:08] "GET /static/css/style.css HTTP/1.1" 304 -
Feb 19 14:30:08 www.team18.isucdc.com flask[962]: 199.100.16.101 - - [19/Feb/2026 14:30:08] "GET /static/js/tickets.js HTTP/1.1" 304 -
Feb 19 14:30:08 www.team18.isucdc.com flask[962]: 199.100.16.101 - - [19/Feb/2026 14:30:08] "GET /get_tickets HTTP/1.1" 200 -
Feb 19 14:30:12 www.team18.isucdc.com flask[962]: 199.100.16.101 - - [19/Feb/2026 14:30:12] "GET /buy_ticket?check=on HTTP/1.1" 400 -
Feb 19 14:34:00 www.team18.isucdc.com flask[962]: 68.32.254.50 - - [19/Feb/2026 14:34:00] "GET /login HTTP/1.1" 200 -
Feb 19 14:34:00 www.team18.isucdc.com flask[962]: 68.32.254.50 - - [19/Feb/2026 14:34:00] "GET / HTTP/1.1" 200 -
Feb 19 14:34:00 www.team18.isucdc.com flask[962]: 68.32.254.50 - - [19/Feb/2026 14:34:00] "POST /login HTTP/1.1" 200 -
```

Figure 21. Application Logs

Monitoring of logs enables detection of brute force attempts, injection attacks, and abnormal application behavior.

Auditing identified vulnerabilities including insufficient file upload validation, authentication weaknesses, insecure token handling, and excessive endpoint exposure.

These vulnerabilities could enable remote code execution, unauthorized access, and data leakage.

Mitigation actions included implementing input validation, enforcing authentication checks, restricting endpoint exposure, sanitizing user input, patching vulnerable code sections, and enabling comprehensive logging. These measures significantly strengthened application security and reduced exploitation risk.

Additionally, the web server operates on AlmaLinux 9 and runs as a frontend service managed through systemd.

Root SSH login was disabled, and firewall rules were configured to allow HTTP traffic while restricting SSH access. Environment variables and configuration files were reviewed to prevent exposure of sensitive credentials.

Blue Flags placed on the Linux-based web server were stored within the /etc/ directory and configured with rw-r--r-- (644) permissions, ensuring compliance with competition requirements.

7. Flags

In the context of a Cyber Defense Competition (CDC), flags are used as a **primary scoring mechanism** to evaluate the availability, integrity, and correct operation of deployed services. Flags represent protected data that must remain accessible through the intended service while being protected against unauthorized access or modification [8]

Blue Flags must be placed by the defending team on their servers **before the attack phase begins**. Flags may be implemented as files stored in predefined directories or as database entries, as specified by the competition scenario.

File-based flags must use realistic file system permissions, remain visible in standard directory listings, and must not be hidden or obfuscated. Database-based flags are defined by the application, table, and record described in the scenario documentation.

Red Flags may be planted by the Red Team if they successfully gain write access to protected locations, typically requiring elevated privileges. The presence of a Red Flag indicates a security compromise.

Validation included verification of directory permissions and file ownership.

Flags placed on the web server were integrated within application directories and protected through permission enforcement and application logic restrictions.

Figure 22. WWW flag Placement

Application configuration ensured that flags were not exposed through unintended endpoints or file traversal vulnerabilities.

Flags associated with directory services were stored within designated directories accessible to authorized administrative accounts. Permission auditing ensured restricted access and integrity protection.

Flags placed on endpoint systems were stored within protected directories and verified through permission auditing. Endpoint placement ensures representation of user level systems within flag distribution.

For Linux-based systems (Management Backend and Public Website), Blue Flags were placed within the /etc/ directory and configured with rw-r--r-- (644) permissions as required by the competition scenario.

For Windows-based systems (Active Directory, Ticketing Machine, and Admin UI), Blue Flags were placed within C:\Windows\System32\ using realistic file system permissions and without obfuscation.

All flags were verified prior to the attack phase to ensure compliance and availability.

References

[1] Microsoft inc, "Security policy settings," Microsoft inc , 19 04 2017. [Online]. Available: https://learn.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/security-policy-settings. [Accessed 16 02 2026].

[2] Netgate Docs, "Firewall Fundamentals," Netgate Docs, 25 08 2025. [Online]. Available: https://docs.netgate.com/pfsense/en/latest/firewall/fundamentals.html. [Accessed 12 02 2026].

[3] MITRE ATTACK, "Enterprise Matrix," MITRE ATTACK, 2025. [Online]. Available: https://attack.mitre.org/matrices/enterprise/. [Accessed 13 02 2026].

[4] OpenAI, "ChatGPT," OpenAI, 02 2026. [Online]. Available: https://chat.openai.com/. [Accessed 02 2026].

[5] Netgate Docs, "Network Address Translation," Netgate Docs, 25 11 2025. [Online]. Available: https://docs.netgate.com/pfsense/en/latest/nat/index.html. [Accessed 08 02 2026].

[6] Windows Server, "Active Directory Domain Services overview," Windows Server, 11 03 2025. [Online]. Available: https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/get-started/virtual-dc/active-directory-domain-services-overview. [Accessed 06 02 2026].

[7] OWASP, "OWASP Top Ten Web Application Security Risks," OWASP, 2025. [Online]. Available: https://owasp.org/www-project-top-ten/. [Accessed 05 02 2026].

[8] cdc, "cdc rules," cdc, 2018. [Online]. Available: https://docs.iseage.org/rules/current/. [Accessed 05 02 2026].

[9] Linux Audit, "Linux security blog," Linux Audit, 2025. [Online]. Available: https://linux-audit.com/. [Accessed 06 02 2026].